

Redes Privadas Virtuales (VPN)

Parte 2

Experiencia Educativa: Seguridad en Redes de Cómputo

MRT. Martha Elizabet Domínguez Bárcenas

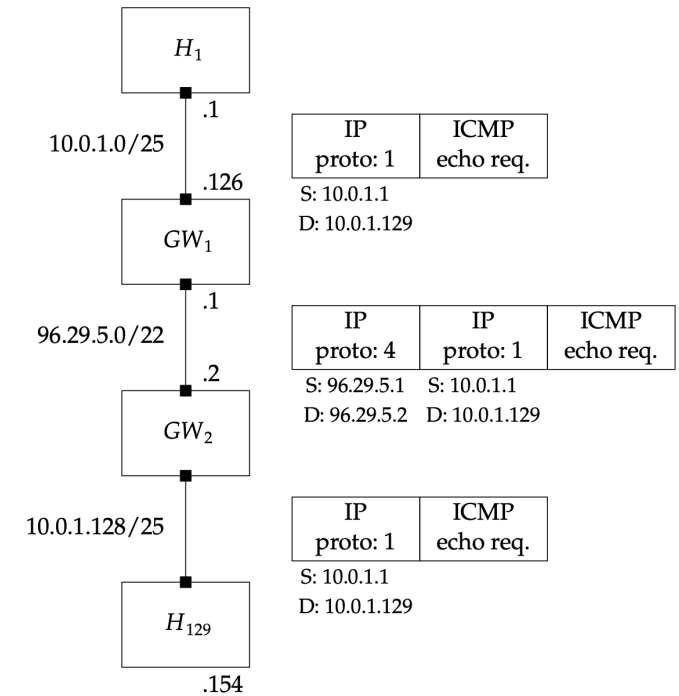
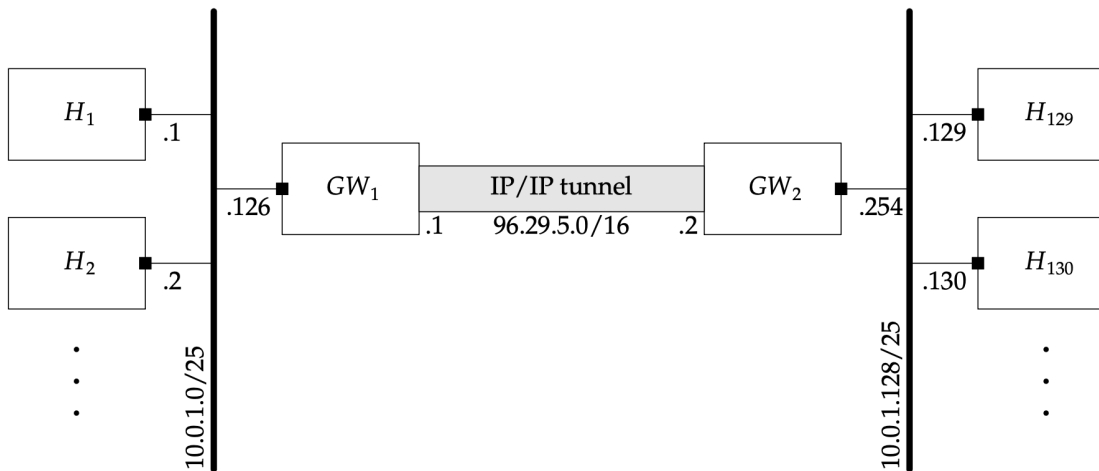


Túneles

- El tunneling o construcción de túneles consiste en la construcción de una red virtual sobre una red física
- Es el acto de encapsular los datos de un protocolo en los datos de otro protocolo de la misma capa o de una capa superior.
- Se dice que el protocolo de encapsulación es un túnel para el protocolo de capa inferior.
- A continuación se analiza la evolución de los protocolos de túnel.

Túneles IP-in-IP (1/2)

- Consiste en encapsular paquetes IP en otros paquetes IP
- Especificación definida en el RFC 2003

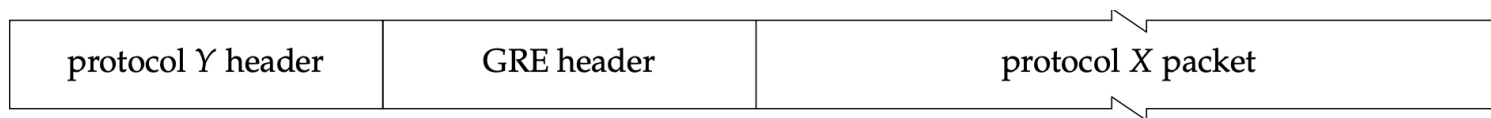


Túneles IP-in-IP (2/2)

- Algunos problemas relacionados
 - Aumento del tamaño de los encabezados (encabezado IP extra de al menos 20 bytes)
 - El paquete podría exceder la MTU de la interface
 - El peer tendría que realizar fragmentación de paquetes
 - Si el paquete original tiene activo el bit de control Don't Fragment (DF). El RFC 2003 especifica que esta misma bandera se debe configurar en el encabezado IP externo.
 - En caso de que el paquete exceda la MTU no podría fragmentarse. El peer simplemente no podría enviar el paquete.
 - El RFC 2003 recomienda que el peer informe al host que la fragmentación es necesaria, para que este pueda ajustar la MTU y los paquetes correspondientes.

Túneles GRE

- Generic Routing Encapsulation (GRE) agrega una interfaz de tipo GRE que agrega el encabezado al principio del paquete X y lo envía para su transmisión al protocolo Y.



- En el peer remoto, la interfaz GRE recibe el paquete Y y lo desencapsula para enviar el paquete X a la capa correspondiente.

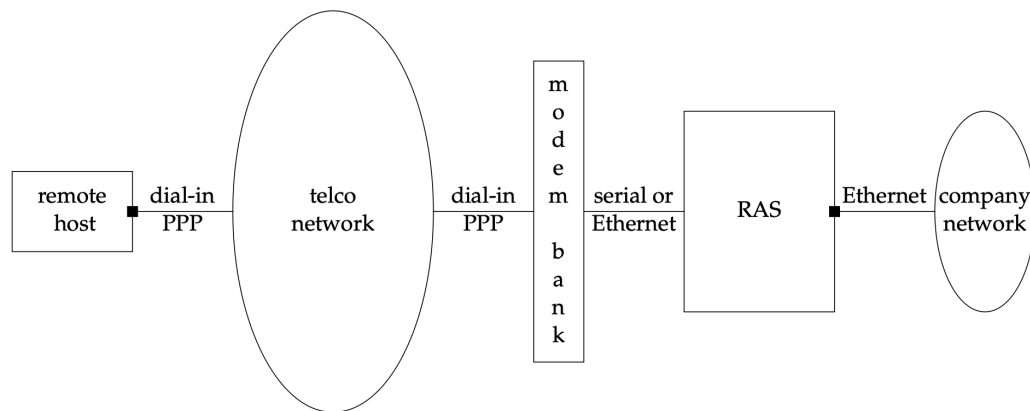
Encabezado GRE

0				2				3				4				12				13				15				16				31			
C				K		S		reserved ₀								version				protocol type															
checksum (optional)																reserved ₁ (optional)																			
key (optional)																																			
sequence number (optional)																																			

- Campos del encabezado:
- **C**, indica que está presente el campo **checksum**. Si la bandera está activa, también se utilizará el campo **reservado₁**
 - El checksum se calcula sobre el encabezado de GRE y su payload
- **K**, indica que el campo **key** estará presente
 - Necesario para identificar un flujo de tráfico particular en el túnel
- **S**, indica que el campo número de secuencia estará presente.
 - Para proporcionar una entrega ordenada del payload (aunque no garantizada)
 - Permite descartar paquetes con el mismo número de secuencia o poner en una cola de espera paquetes con números de secuencia mayores al esperado
- **Versión**, indica el número de versión, originalmente valor 0 (depende del protocolo con el que se use, p.ej., PPTP, valor 1)
- **Protocol type**, indica el protocolo al que va dirigido el payload del paquete. Cuando se usa Ethernet en capa 2, este valor es equivalente al valor del campo Type en Ethernet.

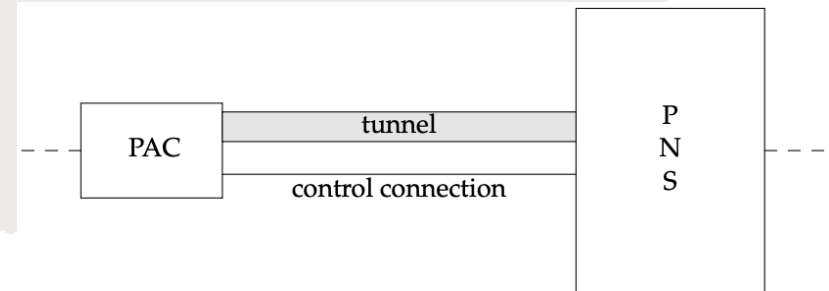
PPTP (1/3)

- Point-to-Point Tunneling Protocol (PPTP)
- Utilizado para túneles de acceso remoto sobre líneas telefónicas que utilizan el **Protocolo Punto a Punto (PPP) a nivel de capa 2**
- Requiere el uso de un Servidor de Acceso Remoto (RAS)



- El RAS se encarga de asignar una dirección IP de la organización para el host remoto

PPTP (2/3)



- PPTP divide las funciones del RAS en:
 - **PPTP Access Concentrator (PAC)**, utilizada por el usuario que marca
 - **PPTP Network Server (PNS)**, termina las sesiones de clientes PPP y proporciona acceso a la red de la organización
- La dupla PAC-PNS proporciona el túnel para el flujo de paquetes entre el host remoto y el PNS
 - El PAC puede ser parte del host remoto, o bien, un host de la organización
 - El usuario remoto establece conexión con el PNS, que proporciona acceso a la red de la organización.
 - El rol del PAC es transferir paquetes PPP entre el host remoto y el PNS a través del túnel.

PPTP (3/3)

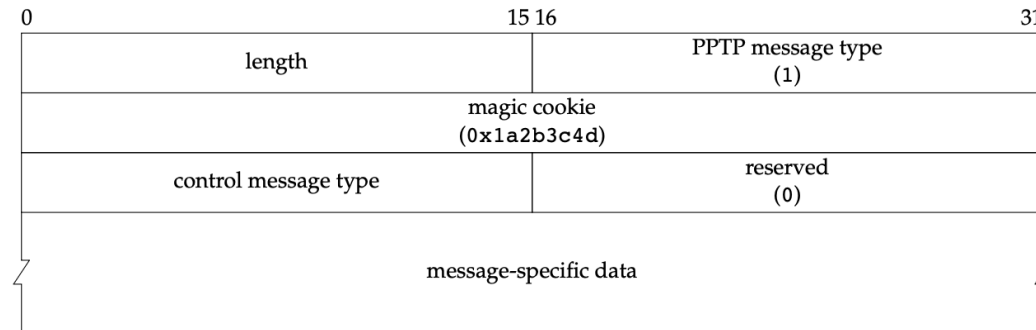


Para el control de la conexión, el PAC y el PNS inician una conexión TCP al puerto 1723.



Una vez establecida la conexión se intercambian mensajes de control PPTP (gestión del control de la conexión, gestión de llamadas, reporte de errores, entre otros)

Encabezado PPTP



Campos del encabezado:

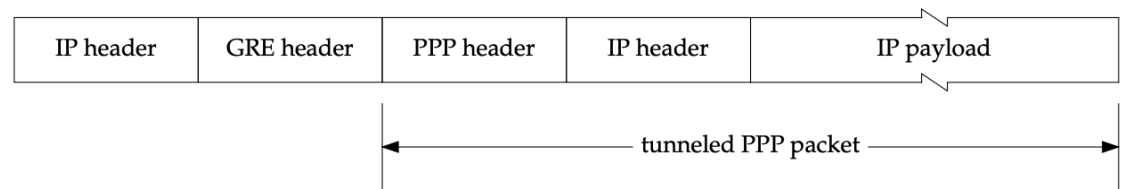
- **Length**, es la longitud del mensaje PPTP, incluyendo el encabezado
- **Message type**, valor 1 si se trata de un mensaje de control
- **Magic cookie**, siempre tiene el valor 0x1a2b3c4d, se utiliza para la sincronización con el flujo TCP. Si el mensaje no contiene este valor, el receptor sabe que ha perdido la sincronización
- **Control message type**, indica el tipo de mensaje de control y el formato del resto del mensaje. Utilizado para:
 - iniciar (Start-Control-Connection-Request, Start-Control-Connection-Reply)
 - terminar (Stop-Control-Connection-Request, Stop-Control-Connection-Response)
 - y probar la conectividad (Echo-Request).

Túnel PPTP (1/4)

- El túnel establecido es un túnel GRE que encapsula paquetes PPP (versión extendida de GRE)

Cambios:

- Campo adicional: **acknowledgment number**
- Bit adicional: **A**. Indica si está presente el campo ACK
- Campo **key**, se divide en **payload length** (longitud del payload) y **call id** (para identificar la conexión).



0	1	2	3	4		7	8	9		12	13		15	16		31
0	0	1	S		reserved ₀ (0)	A		reserved ₁ (0)		version (1)		protocol type				
payload length											call ID					
sequence number (optional)																
acknowledgment number (optional)																

Túnel PPTP (2/4)

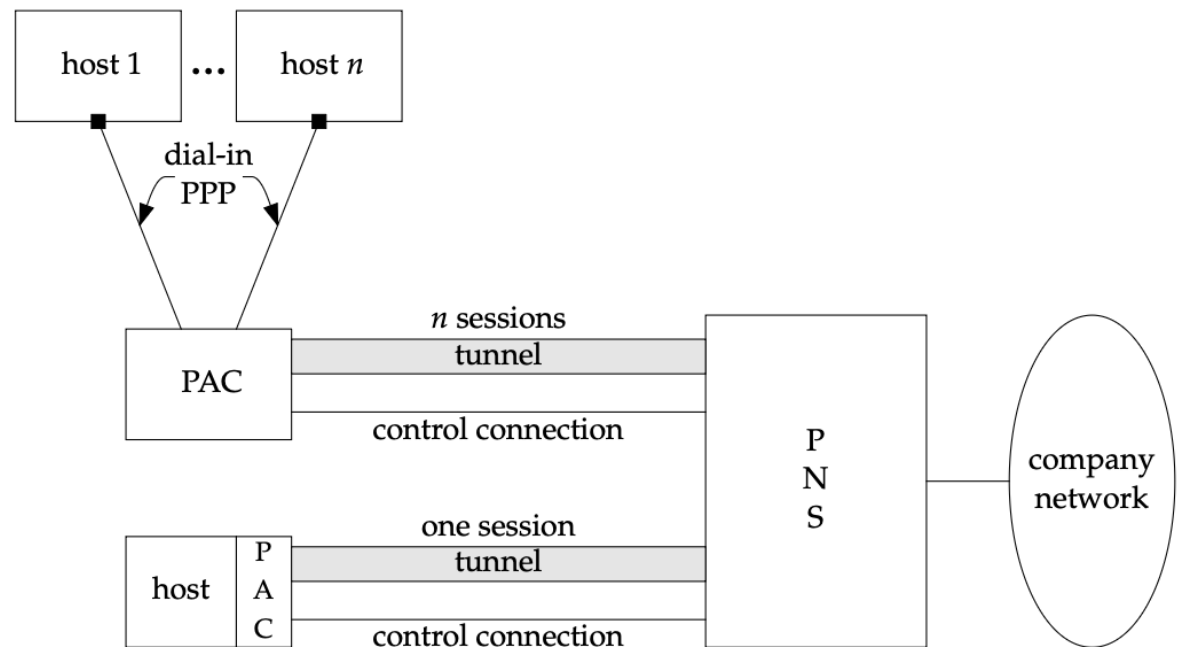
Modo obligatorio (Mandatory)

Los usuarios se conectan mediante PPP a un servidor de acceso telefónico – por ejemplo, de un ISP –

Los usuarios no se dan cuenta que utilizan un túnel

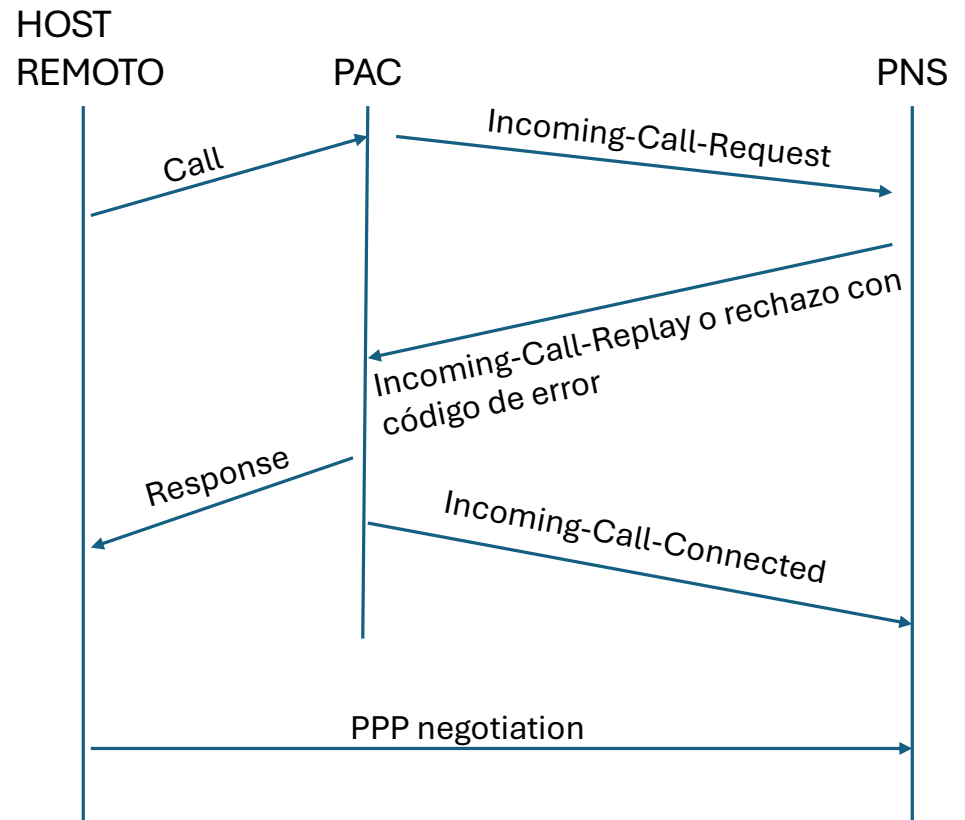
Modo voluntario (Voluntary)

El host remoto está directamente involucrado en el mecanismo del túnel y puede elegirse lo usa.



Túnel PPTP (3/4)

- Cuando un host remoto se conecta al PAC, el PAC envía un Incoming-Call-Request al PNS
- El PNS responde con un Incoming-Call-Replay aceptando la llamada o bien, especificando un código de error para rechazarla
- Cuando el PAC recibe el Incoming-Call-Replay, puede responder la llamada del host
- El PAC completa el establecimiento de la sesión enviando un mensaje Incoming-Call-Connected al PNS. En este punto, el host remoto y el PNS inician la negociación PPP (PPP LCP)



Túnel PPTP (4/4)

- PPTP es un tipo de servidor de acceso remoto que no requiere gran inversión
- No utiliza mecanismos de cifrado o autenticación
- PPTP es un protocolo de túnel, no un protocolo de VPN
- PPTP confía en el protocolo subyacente (PPP) para los servicios de cifrado y autenticación
- No hay autenticación por paquete. Esto implica que puede haber ataques de manipulación de bits sobre datos cifrados

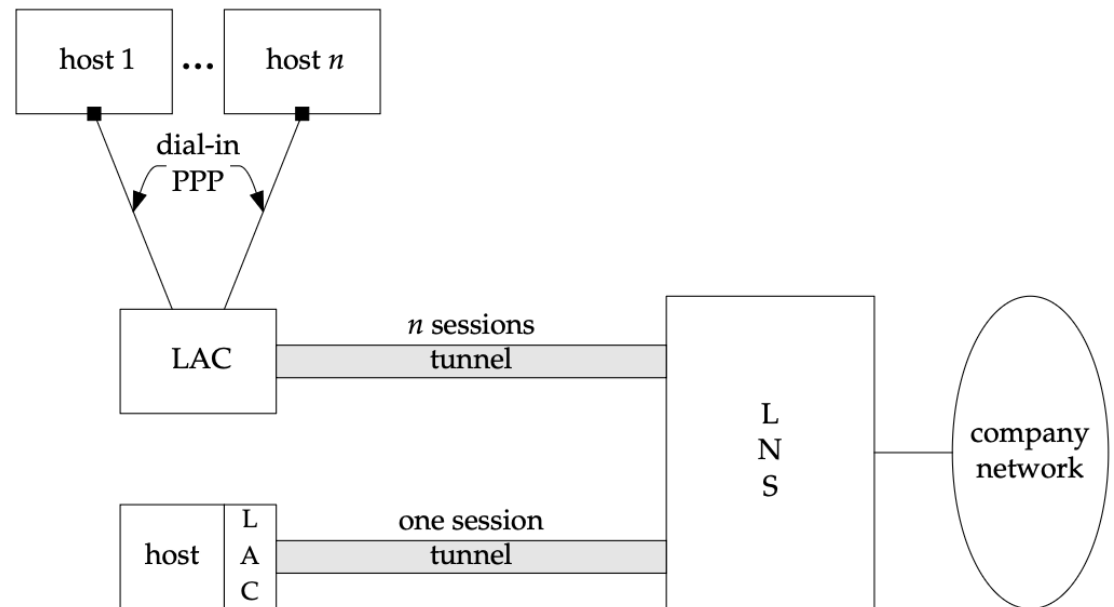


L2TP

- PPP utiliza TCP para controlar el canal, restringiendo su uso a redes IP
 - Cisco desarrollo un protocolo propietarios llamado Layer Two Forwarding (L2F), similar a PPTP, pero que podía operar sobre un protocolo de capa de enlace
 - El IETF combinó las ideas de PPTP y L2F para crear un protocolo llamado **Layer two Tunneling Protocol (L2TP)**
 - El objetivo de L2TP es dividir las funciones del RAS en dos partes:
 - **L2TP Access Concentrator (LAC)**. Maneja la comunicación física con el host remoto
 - **L2TP Network Server (LNS)**. Actúa como gateway en la red privada
- 

L2TP

- L2TP puede operar en:
 - Modo Mandatory. El host remoto se conecta a un LAC autónomo
 - Modo Voluntary. El LAC reside en el host remoto
- Diferencias con PPTP
 - No existe una conexión independiente entre LAC y LNS
 - La información de control se envía a través del mismo túnel
 - Permite conexiones distintas a PPP
 - El control de conexión es independiente de TCP



Encapsulamiento L2TP

- En lugar de usar GRE, L2TP utiliza datagramas UDP. Esto facilita la interoperabilidad de L2TP con NAT
- El encabezado L2TP incluye información sobre la sesión
- Hay dos tipos de mensajes
 - **Mensajes de control.** Conexiones usadas para establecer y gestionar el túnel L2TP, iniciar y terminar sesiones de usuario
 - **Mensajes de datos.** Conexiones que llevan paquetes de datos (por ejemplo, frames PPP) del host remoto al LNS

Encabezado L2TP

- Ambos tipos de mensajes inician con un encabezado común
- El **encabezado es ampliable** en dos sentidos
 - Muchos de los **campos** son **opcionales**
 - Se pueden agregar **campos adicionales**, dependiendo del tipo de información que lleve el mensaje. Estos campos adicionales son en forma de tipo-longitud-valor, por lo que reciben el nombre de **Par de Atributo Valor (AVP)**, por sus siglas en inglés)

Encabezado L2TP

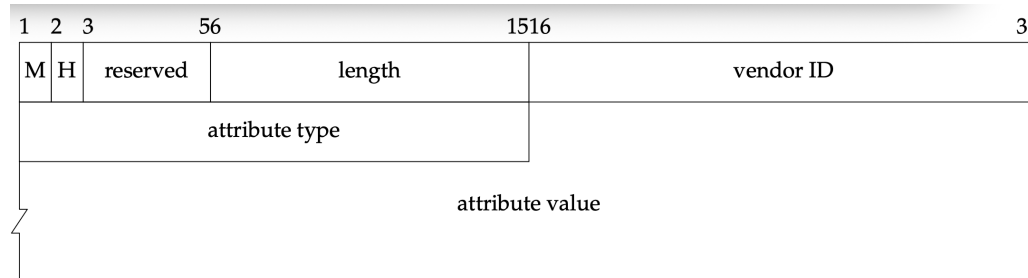
0	1			4		6	7							13	15	16														31
T	L	x	x	S	x	O	P	x	x	x	x	x	x	version	length (optional)															
tunnel ID															session ID															
Ns (optional)															Nr (optional)															
offset size (optional)															offset pad (optional)															

Descripción de los campos:

- **T**, permite distinguir los mensajes de control de los mensajes de sesión. Se establece un valor para los mensajes de control y se deja en blanco para otro tipo de mensajes
- **L**, indica que está presente el campo longitud. Siempre fijado en los mensajes de control, opcional para otro tipo de mensajes
 - Length, especifica la longitud total del mensaje, incluyendo el encabezado. Puede ser de hasta 65,535 bytes, pero con redes IP, se debe ajustar al campo longitud (de 16 bits) de IP.
- **S**, indica si están presentes los campos Número de secuencia: Ns y Nr. Siempre presentes para los mensajes de control.
 - Uso equivalente a los campos Sequence Number (Ns) y ACK de TCP (Nr)
- **O**, indica si el campo Offset está presente. Siempre en blanco para mensajes de control
- **P**, indica que el mensaje debe tener prioridad para encolamiento y transmisión en la máquina local (por ejemplo para mensajes keep-alive). En blanco para mensajes de control.
- **Version**, siempre con valor 2 para mensajes L2TP
- **Tunnel ID**, identifica un túnel en particular
- **Sesión ID**, identifica una sesión particular a la que pertenece el mensaje de datos
- **Offset size y Offset pad**, se usan para rellenar el encabezado, si es necesario. Offset size indica el número de bytes después de este campo, donde inician los datos. Estos campos no están presentes en los mensajes de control.

Par de Atributo Valor (AVP)

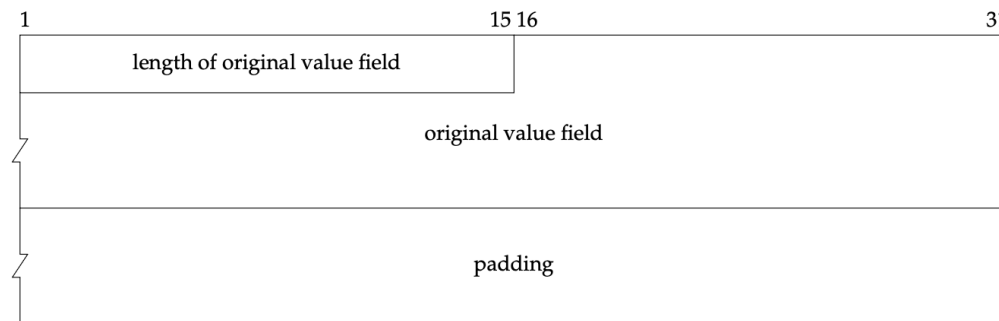
- **Campos en los mensajes de control**, distintos a los del encabezado común



- **M**, indica que este AVP es obligatorio (mandatory). Si no es establecido, el receptor debe ignorar el AVP
- **H**, *hidden bit*, indica que este **AVP está cifrado**. Se utiliza **para transmitir passwords y otros parámetros sensibles**.
- **Length**, número de bytes en el AVP
- **Vendor ID**, valor 0 indica que los valores de los tipos de atributos son los definidos en la especificación L2TP (RFC 2661). Los proveedores pueden obtener su propio vendor ID del IETF (con atributos propietarios)
- **Attribute type**, campo de 16 bits que especifica que parámetros de este AVP se están llevando
- **Attribute value**, indica el valor de los parámetros correspondientes

Cifrado de AVPs (1/2)

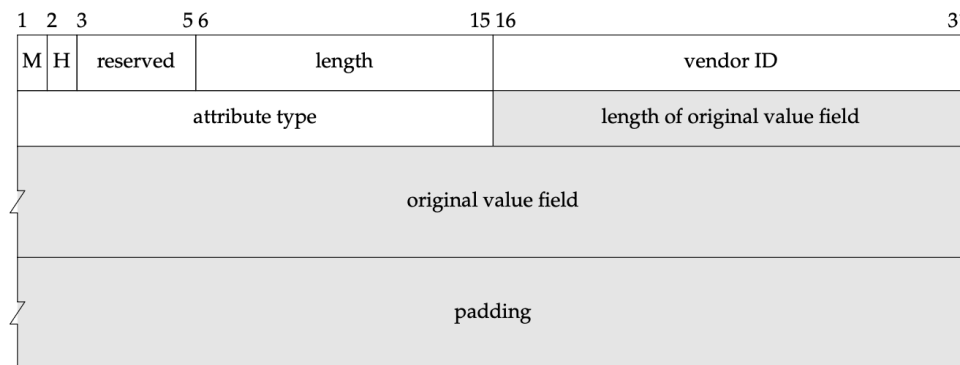
- Para que tenga lugar el cifrado, LAC y LNS deben tener una **clave compartida**
- Un mensaje que tiene un hidden AVP (AVP cifrado), debe tener un **random vector**, que será utilizado como parte de la llave para el proceso de cifrado
- El AVP se codifica de la siguiente manera



- **Original length**, contiene la longitud original del campo valor (que quedará oculta por el padding y el cifrado)
 - Usado por el receptor para poder descartar el padding y quedarse con el valor original
- **Padding**, cantidad arbitraria de relleno para ocultar la longitud original

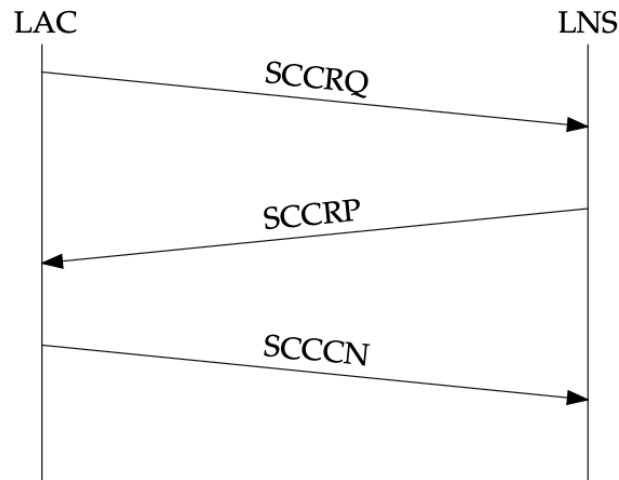
Cifrado de AVPs (2/2)

- AVP final después de cifrar (solo se cifra la porción sombreada):



- El cifrado se realiza contatenando:
 - Los 2 bytes de **attribute type**
 - El **secreto compartido**
 - La longitud arbitraria del *random vector*
- Después se toma el hash MD5 del resultado.

Establecimiento del túnel L2TP



SCCRQ – Start-Control-Connection-Request

SCCRP - Start-Control-Connection-Reply

- Si el peer **rechaza la conexión** responde con un StopCCN y el código de error correspondiente.
- Si los **parámetros** del SCCRP son **aceptables** para el iniciador del túnel, envía un SCCCN

SCCCN – Start-Control-Connection-Connected

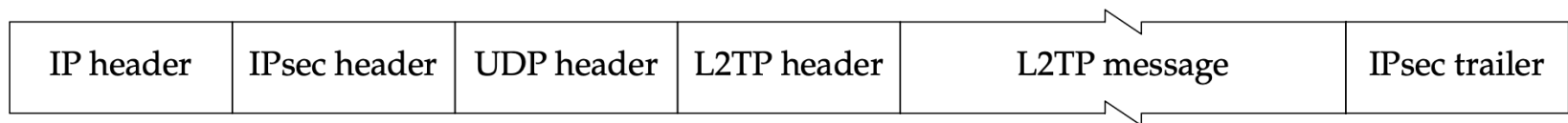
- Si **no son aceptables**, responde con un StopCCN
- Si se recibe el SCCCN, el túnel queda establecido

Túnel L2TP

- L2TP tiene una **seguridad integrada mínima**
- El LAC y el LNS se pueden autenticar durante la configuración del túnel y los AVPs se pueden cifrar, pero al igual que PPTP, la **protección de los datos del usuario en el túnel dependen de PPP**
- PPP maneja dos tipos de **autenticación** para el establecimiento de la sesión: Password Authentication Protocol (PAP) y Challenge Handshake Authentication Protocol (CHAP). También puede manejar **cifrado** de tramas.
- **Ni los mensajes PPP, ni los mensajes L2TP son autenticados**, por lo que podrían ser sujeto de varias manipulaciones.
- Algo importante a resaltar: el cifrado No provee autenticación de mensajes. Por lo que aún los mensajes cifrados podrían ser manipulados por un atacante
- Un atacante podría responder mensajes previos para confundir al protocolo o a la aplicación
- Otro problema es el uso de una **clave compartida** para la autenticación de los endpoints. Si la clave se ve comprometida, todo el tráfico anterior y futuro podría ser leído.
- La **clave compartida** tienen una larga vida (**no se actualiza**). Si un atacante acumula grandes cantidades de datos cifrados. Podría llegar a descubrir la llave con un criptoanálisis.

L2TP e IPsec

- Debido a las debilidades de seguridad que presenta, muchos expertos consideran a L2TP una tecnología de acceso remoto, más que una VPN
- Sin embargo, los usuarios tienden a pensar en L2TP como una tecnología para proteger sus comunicaciones
- Solución: Combinar L2TP con un protocolo externo de seguridad (L2TP sobre IPsec)
- IPsec proporciona cifrado, autenticación y otros servicios de seguridad en la capa de red. Particularmente con el uso de Encapsulating Security Payload (ESP), donde el payload del paquete IP es cifrado y autenticado mientras se transmite entre LAC y LNS



OpenVPN

- Ofrece seguridad comparable con IPsec
- Utiliza TLS/SSL para la autenticación de los endpoints y el intercambio de claves
- Logra un comportamiento similar a ESP para el canal de datos.

Referencias

- Snader, J. C. (2006). *VPNs illustrated: Tunnels, VPNs, and IPsec*. Addison-Wesley Professional.